

Procedures and tools

Data recovery procedures should be defined in the data management process described in CIS Control 3, Data Protection. This should include backup procedures based on data value, sensitivity, or retention requirements. This will assist in developing backup frequency and type (full vs. incremental).

Once per quarter (or whenever a new backup process or technology is introduced), a testing team should evaluate a random sampling of backups and attempt to restore them on a test bed environment. The restored backups should be verified to ensure that the operating system, application, and data from the backup are all intact and functional.

In the event of malware infection, restoration procedures should use a version of the backup that is believed to predate the original infection.

Safeguards

Safeguard 11.1: Establish and Maintain a Data Recovery Process

Asset Type: Documentation	Security Function: Govern	IG1	IG2	IG3
---------------------------	---------------------------	-----	-----	-----

Establish and maintain a documented data recovery process that includes detailed backup procedures. In the process, address the scope of data recovery activities, recovery prioritization, and the security of backup data. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 11.2: Perform Automated Backups

Asset Type: Data	Security Function: Recover	IG1	IG2	IG3
------------------	----------------------------	-----	-----	-----

Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data.

Safeguard 11.3: Protect Recovery Data

Asset Type: Data	Security Function: Protect	IG1	IG2	IG3
------------------	----------------------------	-----	-----	-----

Protect recovery data with equivalent controls to the original data. Reference encryption or data separation, based on requirements.

Safeguard 11.4: Establish and Maintain an Isolated Instance of Recovery Data

Asset Type: Data	Security Function: Recover	IG1	IG2	IG3
------------------	----------------------------	-----	-----	-----

Establish and maintain an isolated instance of recovery data. Example implementations include, version controlling backup destinations through offline, cloud, or off-site systems or services.

Safeguard 11.5: Test Data Recovery

Asset Type: Data	Security Function: Recover	IG2	IG3
------------------	----------------------------	-----	-----

Test backup recovery quarterly, or more frequently, for a sampling of in-scope enterprise assets.

CONTROL 12

Network Infrastructure Management

Safeguards: 8	IG1: 1/8	IG2: 7/8	IG3: 8/8
---------------	----------	----------	----------

Overview

Establish, implement, and actively manage (track, report, correct) network devices, in order to prevent attackers from exploiting vulnerable network services and access points.

Why is this Control critical?

Secure network infrastructure is an essential defense against attacks. This includes an appropriate security architecture, addressing vulnerabilities that are, often times, introduced with default settings, monitoring for changes, and reassessment of current configurations. Network infrastructure includes devices such as physical and virtualized gateways, firewalls, wireless access points, routers, and switches.

Default configurations for network devices are geared for ease-of-deployment and ease-of-use—not security. Potential default vulnerabilities include open services and ports, default accounts and passwords (including service accounts), support for older vulnerable protocols, and pre-installation of unneeded software. Attackers search for vulnerable default settings, gaps or inconsistencies in firewall rule sets, routers, and switches and use those holes to penetrate defenses. They exploit flaws in these devices to gain access to networks, redirect traffic on a network, and intercept data while in transmission.

Network security is a constantly changing environment that necessitates regular re-evaluation of architecture diagrams, configurations, access controls, and allowed traffic flows. Attackers take advantage of network device configurations becoming less secure over time as users demand exceptions for specific business needs. Sometimes the exceptions are deployed, but not removed when they are no longer applicable to the business’s needs. In some cases, the security risk of an exception is neither properly analyzed nor measured against the associated business need and can change over time.

Procedures and tools

Enterprises should ensure network infrastructure is fully documented and architecture diagrams are kept up-to-date. It is important for key infrastructure components to have vendor support for patches and feature upgrades. Upgrade End-of-Life (EOL) components before the date they will be out of support or apply mitigating controls to isolate them. Enterprises need to monitor their infrastructure versions and configurations for vulnerabilities that would require them to upgrade the network devices to the latest secure and stable version that does not impact the infrastructure.

An up-to-date network architecture diagram, including security architecture diagrams, are an important foundation for infrastructure management. Next is having complete account management for access control, logging, and monitoring. Finally, infrastructure administration should only be performed over secure protocols, with strong authentication (MFA for PAM), and from dedicated administrative devices or out-of-band networks.

Commercial tools can be helpful to evaluate the rule sets of network filtering devices to determine whether they are consistent or in conflict. This provides an automated sanity check of network filters. These tools search for errors in rule sets or Access Controls Lists (ACLs) that may allow unintended services through the network device. Such tools should be run each time significant changes are made to firewall rule sets, router ACLs, or other filtering technologies.

For telework and small office guidance, refer to the [CIS Controls Telework and Small Office Network Security Guide](#):

<https://www.cisecurity.org/controls/resources?crc=environment-specific-guidance>

Safeguards

Safeguard 12.1: Ensure Network Infrastructure is Up-to-Date

Asset Type:	Network	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Ensure network infrastructure is kept up-to-date. Example implementations include running the latest stable release of software and/or using currently supported network as a service (NaaS) offerings. Review software versions monthly, or more frequently, to verify software support.

Safeguard 12.2: Establish and Maintain a Secure Network Architecture

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Design and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum. Example implementations may include documentation, policy, and design components.

Safeguard 12.3: Securely Manage Network Infrastructure

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Securely manage network infrastructure. Example implementations include version-controlled-infrastructure-as-code, and the use of secure network protocols, such as SSH and HTTPS.

Safeguard 12.4: Establish and Maintain Architecture Diagram(s)

Asset Type:	Documentation	Security Function:	Govern	IG2	IG3
-------------	---------------	--------------------	--------	-----	-----

Establish and maintain architecture diagram(s) and/or other network system documentation. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 12.5: Centralize Network Authentication, Authorization, and Auditing (AAA)

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Centralize network AAA.

Safeguard 12.6: Use of Secure Network Management and Communication Protocols

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Adopt secure network management protocols (e.g., 802.1X) and secure communication protocols (e.g., Wi-Fi Protected Access 2 (WPA2) Enterprise or more secure alternatives).

Safeguard 12.7: Ensure Remote Devices Utilize a VPN and are Connecting to an Enterprise’s AAA Infrastructure

Asset Type: Devices	Security Function: Protect	IG2 IG3
----------------------------	-----------------------------------	-----------------------

Require users to authenticate to enterprise-managed VPN and authentication services prior to accessing enterprise resources on end-user devices.

Safeguard 12.8: Establish and Maintain Dedicated Computing Resources for All Administrative Work

Asset Type: Devices	Security Function: Protect	IG3
----------------------------	-----------------------------------	------------

Establish and maintain dedicated computing resources, either physically or logically separated, for all administrative tasks or tasks requiring administrative access. The computing resources should be segmented from the enterprise’s primary network and not be allowed internet access.

CONTROL 13

Network Monitoring and Defense

Safeguards: 11	IG1: 0/11	IG2: 6/11	IG3: 11/11
----------------	-----------	-----------	------------

Overview

Operate processes and tooling to establish and maintain comprehensive network monitoring and defense against security threats across the enterprise’s network infrastructure and user base.

Why is this Control critical?

We cannot rely on network defenses to be perfect. Adversaries continue to evolve and mature, as they share, or sell, information among their community on exploits and bypasses to security controls. Even if security tools work “as advertised,” it takes an understanding of the enterprise risk posture to configure, tune, and log them to be effective. Often, misconfigurations due to human error or lack of knowledge of tool capabilities give enterprises a false sense of security.

Security tools can only be effective if they are supporting a process of continuous monitoring that allows staff the ability to be alerted and respond to security incidents quickly. Enterprises that adopt a purely technology-driven approach will also experience more false positives, due to their over-reliance on alerts from tools. Identifying and responding to these threats requires visibility into all threat vectors of the infrastructure and leveraging humans in the process of detection, analysis, and response. It is critical for large or heavily targeted enterprises to have a security operations capability to prevent, detect, and quickly respond to cyber threats before they can impact the enterprise. This process will generate activity reports and metrics that will help enhance security policies, and support regulatory compliance for many enterprises.

As we have seen many times in the press, enterprises have been compromised for weeks, months, or years before discovery. The primary benefit of having comprehensive situational awareness is to increase the speed of detection and response. This is critical to respond quickly when malware is discovered, credentials are stolen, or when sensitive data is compromised to reduce impact to the enterprise.

Through good situational awareness (i.e., security operations), enterprises will identify and catalog Tactics, Techniques, and Procedures (TTPs) of attackers, including their IOCs that will help the enterprise become more proactive in identifying future threats or incidents. Recovery can be achieved faster when the response has access to complete information about the environment and enterprise structure to develop efficient response strategies.

Procedures and tools

Most enterprises do not need to stand up a Security Operations Center (SOC) to gain situational awareness. This starts with first understanding critical business functions, network and server architectures, data and data flows, vendor service and business partner connection, and end-user devices and accounts. This informs the development of a security architecture, technical controls, logging, monitoring, and response procedures.

At the core of this process is a trained and organized team that implements processes for incident detection, analysis, and mitigation. These capabilities could be conducted internally, or through consultants or a managed service provider. Enterprises should consider network, enterprise asset, user credential, and data access activities. Technology will play a crucial role to collect and analyze all of the data, and monitor networks and enterprise assets internally and externally to the enterprise. Enterprises should include visibility to cloud platforms that might not be in line with on-premises security technology.

Forwarding all important logs to analytical programs, such as Security Information and Event Management (SIEM) solutions, can provide value; however, they do not provide a complete picture. Weekly log reviews are necessary to tune thresholds and identify abnormal events. Correlation tools can make audit logs more useful for subsequent manual inspection. These tools are not a replacement for skilled information security personnel and system administrators. Even with automated log analysis tools, human expertise and intuition are often required to identify and understand attacks.

As this process matures, enterprises will create, maintain, and evolve a knowledge base that will help to understand and assess the business risks, developing an internal threat intelligence capability. Threat intelligence is the collection of TTPs from incidents and adversaries. To accomplish this, a situational awareness program will define and evaluate which information sources are relevant to detect, report, and handle attacks. Most mature enterprises can evolve to threat hunting, where trained staff manually review system and user logs, data flows, and traffic patterns to find anomalies.

Safeguards

Safeguard 13.1: Centralize Security Event Alerting

Asset Type:	Network	Security Function:	Detect	IG2	IG3
-------------	---------	--------------------	--------	-----	-----

Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard.

Safeguard 13.2: Deploy a Host-Based Intrusion Detection Solution

Asset Type:	Devices	Security Function:	Detect	IG2	IG3
-------------	---------	--------------------	--------	-----	-----

Deploy a host-based intrusion detection solution on enterprise assets, where appropriate and/or supported.

Safeguard 13.3: Deploy a Network Intrusion Detection Solution

Asset Type:	Network	Security Function:	Detect	IG2	IG3
-------------	---------	--------------------	--------	-----	-----

Deploy a network intrusion detection solution on enterprise assets, where appropriate. Example implementations include the use of a Network Intrusion Detection System (NIDS) or equivalent cloud service provider (CSP) service.

Safeguard 13.4: Perform Traffic Filtering Between Network Segments

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Perform traffic filtering between network segments, where appropriate.

Safeguard 13.5: Manage Access Control for Remote Assets

Asset Type:	Devices	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Manage access control for assets remotely connecting to enterprise resources. Determine amount of access to enterprise resources based on: up-to-date anti-malware software installed, configuration compliance with the enterprise's secure configuration process, and ensuring the operating system and applications are up-to-date.

Safeguard 13.6: Collect Network Traffic Flow Logs

Asset Type:	Network	Security Function:	Detect	IG2	IG3
-------------	---------	--------------------	--------	-----	-----

Collect network traffic flow logs and/or network traffic to review and alert upon from network devices.

Safeguard 13.7: Deploy a Host-Based Intrusion Prevention Solution

Asset Type:	Devices	Security Function:	Protect	IG3
-------------	---------	--------------------	---------	-----

Deploy a host-based intrusion prevention solution on enterprise assets, where appropriate and/or supported. Example implementations include use of an Endpoint Detection and Response (EDR) client or host-based IPS agent.

Safeguard 13.8: Deploy a Network Intrusion Prevention Solution

Asset Type:	Network	Security Function:	Protect	IG3
-------------	---------	--------------------	---------	-----

Deploy a network intrusion prevention solution, where appropriate. Example implementations include the use of a Network Intrusion Prevention System (NIPS) or equivalent CSP service.

Safeguard 13.9: Deploy Port-Level Access Control

Asset Type:	Network	Security Function:	Protect	IG3
-------------	---------	--------------------	---------	-----

Deploy port-level access control. Port-level access control utilizes 802.1x, or similar network access control protocols, such as certificates, and may incorporate user and/or device authentication.

Safeguard 13.10: Perform Application Layer Filtering

Asset Type:	Network	Security Function:	Protect	IG3
-------------	---------	--------------------	---------	-----

Perform application layer filtering. Example implementations include a filtering proxy, application layer firewall, or gateway.

Safeguard 13.11: Tune Security Event Alerting Thresholds

Asset Type:	Network	Security Function:	Detect	IG3
-------------	---------	--------------------	--------	-----

Tune security event alerting thresholds monthly, or more frequently.